

Incident Response Plan

SEVERITY: HIGH

Sensitive medical insurance data potentially at risk

Incident Summary:

Suspected phishing / Malware Compromise – Employee device

A colleague's personal device displayed a message confirming a malicious link had been clicked which is consistent with a successful phishing or malware execution. This is handled as a verified high-severity issue that has to be addressed urgently as the company handles extremely sensitive medical insurance information.

Detection:

The on-screen message is treated as a confirmed indicator of compromise rather than a false alert, given its purposeful mocking phrasing.

Analysis:

- Ask questions to the colleague:
 - What was clicked?
 - When?
 - From where (email, SMS, website)?
- Check whether the device has accessed the company network, VPN, or cloud accounts
- Inspect processes, downloads, and browser history for malicious artefacts
- Determine whether the device stores or accesses any client's medical or personal data and information?

Containment:

- Immediately disconnect the affected device from the network but not switch it off to preserve evidence.
- Disable compromised user accounts if necessary.
- Block malicious IP addresses, domains and email sources associated with the attack.
- Monitor the network for further suspicious activity.
- Alert IT to monitor the corporate network for related abnormal activity.

Eradication:

- Run a full malware scan and restore the device if infection is confirmed
- Remove malware, malicious extensions and persistence mechanisms found using approved security tools.
- Patch vulnerabilities and update affected systems
- Reset compromised passwords and review access controls.

Recovery:

- Restore affected systems and files from verified backups.
- Test systems to ensure normal functionality and security.
- Closely monitor the environment for signs of reinfection
- Escalate to legal or compliance if any client data exposure is confirmed

Communication:

- Provide regular updates to management and relevant stakeholders.
- Notify affected customers and regulators if required by data protection legislation.
- Maintain accurate incident documentation/timeline throughout the response process.

Post-Incident Review:

- Conduct a lesson-learned meeting.
- Update security controls, employee awareness training, and the incident response plan to reduce future risk.

Roles & Responsibilities:

- **Cyber Security Analyst (first respondent):** triage, containment, evidence, preservation
- **IT Support:** Responsible for network isolation, credential resets, device reimaging.
- **Information Security Manager:** Oversees response, confirms severity classification.
- **Legal/Compliance Counsel:** Assesses regulatory notification duties for any data exposure
- **Management:** Kept informed of impact and approves any external communications.